

ACTIVITY PACK

Activity 5: Security Checklist

Activity 5 - Agent Governance and the Deployment Gate

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Security Checklist

Activity 5 - Agent Deployment Gate Checklist

Organisational accountability

- ☐ Business, technical, security, privacy, model-risk and operational owners are named.
- ☐ Leadership has approved the use case, risk tolerance and non-agent alternative.
- ☐ Users are told when an agent acts, what it can access and how to challenge outcomes.

Bound autonomy

- ☐ Each capability is classified by impact, reversibility, data sensitivity and likelihood.
- ☐ Read, recommend, prepare and execute permissions are separated.
- ☐ Irreversible, legal, financial, privacy and safety actions have deterministic approval or are prohibited.
- ☐ Approval shows exact fields, recipient, amount, target and reason and expires after one action.
- ☐ Agent identity, credentials, tools, skills/plugins, recipients, cost, retries and duration are bounded.

Fairness, reliability and privacy

- ☐ Accuracy, false escalation and outcomes meet per-segment floors and disparity limits.
- ☐ Hallucination and unsafe-action rates are converted into expected annual affected cases.
- ☐ Prompt, output, memory, tool and log personal-data surfaces are inventoried and minimised.
- ☐ PDPA purpose, notice/consent where applicable, protection, transfer, retention and rights are evidenced.

Responsible AI assurance

- ☐ The board has tested both attacker-driven misuse and foreseeable harmful use without an attacker.
- ☐ Outcome, denial, escalation and false-positive results are segmented by affected group.
- ☐ Users receive clear notice of agent use, material limitations, data/tool reach and the human escalation route.
- ☐ Affected people can obtain human review, correction and remedy for consequential outcomes.
- ☐ Provider, builder, deployer, operator, approver and end-user responsibilities are documented without gaps.
- ☐ Independent or second-line review is required where impact exceeds the organisation's defined threshold.

Operations

- ☐ Monitoring covers identity, tool sequences, approvals, overrides, egress, cost and policy denials.
- ☐ Kill switch, rollback, credential revocation and manual fallback are tested.
- ☐ Incident response includes the DPO, evidence preservation and breach-notification assessment.
- ☐ Model, corpus, tool, skill/plugin or policy changes automatically trigger re-testing.
- ☐ Residual risks have owners, mitigations and expiry dates.

Board decision

- ☐ Go.
- ☐ Go with explicit conditions and expiry.
- ☐ No-go; the use case cannot be bounded within risk tolerance.